

NIS2 Art. 21(2) Compliance Mapping

Maps Goya Ledger controls to NIS2 Directive (EU 2022/2555) Art. 21(2) categories, ETSI EN 319 401 v3.2.1 clauses, and CIR 2025/2160 requirements.

Audit date: 2026-08-31 · Codebase: v0.13.3

Self-assessment. No CAB has validated these claims.

Art. 21(2)(a) — Risk analysis and information system security policies

Requirement	Goya control	Evidence	Gap
Risk assessment methodology	Threat model in SECURITY.md (consensus, crypto, network)	SECURITY.md §Threat Model	Needs formal risk register with likelihood/impact scoring
Information security policy	PLAN-SEGURIDAD.md (DS 181 aligned)	docs/policy/PLAN-SEGURIDAD.md	Needs NIS2 Art. 21 explicit mapping
TSP general policy	ETSI EN 319 401 policy doc	docs/policy/ETSI-EN-319-401-TSP-POLICY.md	References v2.3.1, needs update to v3.2.1

EN 319 401 v3.2.1 clause: 6.3 (Risk assessment)

Art. 21(2)(b) — Incident handling

Requirement	Goya control	Evidence	Gap
Incident response plan	IRP-001 with severity classification	docs/compliance/INCIDENT-RESPONSE-PLAN.md	None
Incident detection	Audit trail middleware,	src/audit.rs, /api/v1/metrics	None

Requirement	Goya control	Evidence	Gap
	Prometheus metrics		
Severity classification	P1-P4 with response times	INCIDENT-RESPONSE-PLAN.md §3	None
ENISA notification (24h early warning)	Documented in SECURITY.md v2.0	SECURITY.md §Vulnerability Disclosure	None
ENISA notification (72h full report)	Documented in SECURITY.md v2.0	SECURITY.md §Vulnerability Disclosure	None
Post-incident analysis	Referenced in IRP	INCIDENT-RESPONSE-PLAN.md	Needs formal template

EN 319 401 v3.2.1 clause: 7.4.8 (Incident management)

Art. 21(2)(c) — Business continuity and crisis management

Requirement	Goya control	Evidence	Gap
Business continuity plan	PLAN-CONTINGENCIA.md with RTO/RPO	docs/policy/PLAN-CONTINGENCIA.md	None
Backup and recovery	RocksDB snapshot + restore procedures	PLAN-CONTINGENCIA.md §6	None
Disaster recovery	DR procedures with geographic failover	PLAN-CONTINGENCIA.md §8	Needs tested runbook
Key ceremony recovery	Documented procedure	docs/policy/PROCEDIMIENTO-CEREMONIA-CLAVES.md	None

EN 319 401 v3.2.1 clause: 7.11 (Business continuity)

Art. 21(2)(d) — Supply chain security

Requirement	Goya control	Evidence	Gap
Software bill of materials	CycloneDX 1.5 SBOM (921 components)	sbom.cdx.json	None

Requirement	Goya control	Evidence	Gap
Dependency audit	cargo-audit capable	Cargo.lock	Needs scheduled runs
Third-party risk assessment	Not formalized	—	Needs vendor assessment process

EN 319 401 v3.2.1 clause: 7.2.4 (Outsourcing)

Art. 21(2)(e) — Security in network and information systems

Requirement	Goya control	Evidence	Gap
Vulnerability handling	CRA-compliant disclosure process	SECURITY.md v2.0, /.well-known/security.txt	None
Vulnerability scanning	cargo-audit, cargo-clippy	CI pipeline	Needs scheduled DAST
Secure development lifecycle	Rust memory safety, clippy -D warnings, fmt, tests	CLAUDE.md pre-commit gate	None
Patch management	cargo update capability	Cargo.toml	Needs documented SLA

EN 319 401 v3.2.1 clause: 7.7 (Development and maintenance)

Art. 21(2)(f) — Policies and procedures for assessing effectiveness

Requirement	Goya control	Evidence	Gap
Security testing	2744 unit tests, PQC gauntlet, Algorithm Death Day	cargo test –lib	None
Penetration testing	pentest.sh script exists	scripts/pentest.sh	Needs third-party engagement
Audit trail	Append-only AuditStore with purge_expired	src/audit.rs	None
Metrics and monitoring		/api/v1/metrics, /api/v1/health	None

Requirement	Goya control	Evidence	Gap
	Prometheus counters, health endpoint		

EN 319 401 v3.2.1 clause: 7.9 (Monitoring and review)

Art. 21(2)(g) — Cybersecurity hygiene and training

Requirement	Goya control	Evidence	Gap
Security awareness training	Not formalized	—	Needs training program
Cybersecurity hygiene practices	Documented in CLAUDE.md, AGENT.md	Repository conventions	Needs employee onboarding doc

EN 319 401 v3.2.1 clause: 7.3 (Human resources)

Art. 21(2)(h) — Cryptographic policies

Requirement	Goya control	Evidence	Gap
Cryptographic algorithm policy	AlgorithmPolicy with deprecation deadlines	src/crypto/algorithm_policy.rs	None
Key management	KeyManager with rotation, HSM abstraction	src/identity/keys.rs	None
PQC readiness	ML-DSA-65, ML-KEM-768, SLH-DSA-128s	pqc_crypto_module/	None
Key zeroization	Implemented for signing providers	SigningProvider Drop impls	None
FIPS 140-3 module boundary	pqc_crypto_module with self-tests	crates/pqc_crypto_module/	CMVP certification pending
Crypto boundary enforcement	cargo test --test crypto_boundary	tests/crypto_boundary.rs	None

EN 319 401 v3.2.1 clause: 7.5 (Cryptographic controls)

Art. 21(2)(i) — Human resources security and access control

Requirement	Goya control	Evidence	Gap
Access control policy	ACL deny-by-default, enforce_acl middleware	src/api/handlers/acl.rs	None
Authentication	mTLS for P2P, JWT for API, X.509 MSP	src/msp/, TLS config	None
Least privilege	Role-based ACL, org-scoped channels	ACL_MODE configuration	None
Key access control	Signing keys in-process only, HSM abstraction	HsmConfig	Needs QSCD (Gap 10)

EN 319 401 v3.2.1 clause: 7.3 (Human resources), 7.4 (Access controls)

Art. 21(2)(j) — Multi-factor authentication and secured communications

Requirement	Goya control	Evidence	Gap
TLS 1.3 for all communications	rustls with PQC hybrid (X25519+ML-KEM-768)	src/network/tls.rs	None
mTLS for P2P	Certificate-based peer authentication	P2P network module	None
MFA for admin operations	Not implemented	—	Needs MFA for admin API

EN 319 401 v3.2.1 clause: 7.6 (Communications security)

Summary

Category	Items	Covered	Gaps
(a) Risk analysis	3	3	Update to v3.2.1, formal risk register
(b) Incident handling	6	6	Post-incident template
	4	4	Tested runbook

Category	Items	Covered	Gaps
(c) Business continuity			
(d) Supply chain	3	2	Vendor assessment
(e) Vulnerability mgmt	4	4	Scheduled DAST
(f) Effectiveness	4	4	Third-party pentest
(g) Training	2	0	Training program
(h) Cryptography	6	6	CMVP pending
(i) Access control	4	4	QSCD pending
(j) MFA/comms	3	2	Admin MFA
Total	39	35	~10 minor gaps

90% of NIS2 Art. 21(2) technical controls are in place. Remaining gaps are organizational (training, vendor assessment, tested runbooks) and will be addressed during CAB engagement.

Next steps for CAB readiness

1. Update ETSI EN 319 401 policy doc from v2.3.1 to v3.2.1 references
2. Create formal risk register (likelihood × impact matrix)
3. Document post-incident analysis template
4. Establish vendor/dependency risk assessment process
5. Create security awareness training program
6. Schedule third-party penetration test
7. Add MFA for admin API operations
8. Engage CAB for pre-assessment